

Unifolio — Data Retention & Deletion Policy

Effective date: 2026-05-13

Last reviewed: 2026-05-13

Owner: Ahmed Al-Samak, CEO (security@unifolio.ca)

Review cadence: Annually, or upon material change to data architecture or applicable privacy law.

1. Purpose

This policy defines how long Unifolio retains each category of user data, when and how that data is deleted, and how deletion is verified. It implements the retention commitments made in our **PRIVACY_POLICY.md** and ensures compliance with PIPEDA (Canada), GDPR (EU/UK), and the Plaid Production Customer Agreement.

2. Data classes and retention schedule

Data class	Examples	Retained while account active?	Retention after deletion request	Backup retention
Account identity	Email, name, password hash, profile photo	Yes	Hard-deleted within 24 hours	Per Supabase tier (currently 7 days on Free)
Portfolio data	Holdings, transactions, realized positions, custom assets, ACB history	Yes	Hard-deleted within 24 hours	Per Supabase tier (currently 7 days on Free)
Plaid connection data	<code>item_id</code> , <code>access_token</code> , institution metadata	Yes	Database record hard-deleted within 24 hours . Active <code>access_token</code> revocation via Plaid	Per Supabase tier (currently 7 days on Free)

Data class	Examples	Retained while account active?	Retention after deletion request	Backup retention
			<code>/item/remove</code> happens immediately when the user explicitly disconnects an Item from Settings; cascading revocation on full-account deletion is a Q3 2026 roadmap item (currently the user is prompted to disconnect Items prior to account deletion).	
Imported broker files	Raw CSV/Flex/PDF uploads	Never stored — only parsed positions/transactions are saved	N/A	N/A
Profile picture asset	Image file in Supabase Storage	Yes	Deleted from Storage immediately on account deletion	Per Supabase tier (currently 7 days on Free)
Transient session data	Auth tokens, session cookies	Until user signs out or 7-day session timeout	Cleared immediately on sign-out	N/A
Operational audit signals	Supabase Auth <code>auth.audit_log_entries</code> (sign-ins, password changes, account deletions); Supabase Postgres logs; Vercel function logs	Yes (vendor-managed)	Retained per Supabase tier policy (currently 7 days on Free; longer on Pro). Application-level audit table is on	Per Supabase tier

Data class	Examples	Retained while account active?	Retention after deletion request	Backup retention
			the 2026 roadmap (see §3.4).	
Email correspondence	Support emails, password reset emails	Stored in Microsoft 365 mailbox	Anonymized or deleted on user request	Per Microsoft 365 policy
Marketing opt-in records	Subscriber list (if applicable)	Until unsubscribe + 30-day suppression list	Removed within 30 days of unsubscribe	N/A

3. Deletion mechanism

3.1 User-initiated deletion (self-service)

Users can permanently delete all their data via:

Settings → Privacy & Data → Delete All Data

The flow:

1. User confirms deletion via a 2-step modal (`DeleteConfirmModal` in `src/pages/PrivacyAndData.jsx`) with a checkbox confirming the action is irreversible.
2. The frontend calls the `delete_unifolio_user_data` Postgres RPC (defined in `supabase/schema.sql`), which deletes the user's rows from: `holdings` , `realized_positions` , `transactions` , `import_batches` , `watchlist` , `accounts` , `institutions` , `user_profiles` . The Supabase Storage `avatars/<user_id>` asset is also deleted from the `avatars` bucket.
3. **Items NOT yet covered by the cascade** (Q3 2026 roadmap fix, tracked in the same milestone as consumer MFA):
 - `plaid_items` rows holding `access_token` values are not removed by the current RPC. Users are prompted in the UI to disconnect every Plaid Item from Settings (which DOES call Plaid's `/item/remove` immediately) prior to triggering account-wide deletion. Once the cascade is wired, the RPC will both call `/item/remove` against Plaid and delete the `plaid_items` row.
 - The `auth.users` row is not removed by the current RPC. The user account can still authenticate but will see an empty portfolio. Permanent auth account removal will be added via a Vercel Edge Function calling Supabase's Admin API (`auth.admin.deleteUser`) in the same Q3 2026 milestone.
- User-entered custom assets (real estate, metals, collectibles) live on a separate legacy backend service (base44). Their deletion is performed by the base44 entity-delete API call from the

frontend during account cleanup, not by the Supabase RPC. A unified server-side cascade is on the same roadmap milestone.

1. **Plaid `access_token` revocation today:** when a user explicitly disconnects a Plaid Item from Settings, Unifolio calls Plaid's `/item/remove` immediately, terminating the connection at both the Unifolio and the bank end.
2. Local browser caches (theme, currency, watchlist, profile picture cache) are cleared by the frontend.
3. The deletion is captured in Supabase's built-in audit infrastructure (see §3.4): the RPC invocation is logged in Supabase Postgres logs, and the HTTP request is logged in Vercel function logs. Unifolio does not currently maintain an additional application-level audit row beyond these vendor-managed logs.

3.2 Account-level deletion (Accounts page)

Users can delete an individual account (one brokerage) without deleting their full Unifolio profile. This:

- Cascades through the account's `holdings`, `transactions`, `realized_positions`, `import_batches`.
- Prunes the parent `institution` row if no other accounts reference it (handled by the `delete_unifolio_account` RPC).
- Revokes the relevant Plaid `access_token` if the account was Plaid-connected.

3.3 Inactive-account expiry

Currently we do **not** auto-delete inactive accounts. If we introduce auto-expiry in future, we will:

- Notify the user 30 days before deletion via email.
- Default to a 24-month-of-inactivity threshold.
- Update this policy and notify users of the change.

3.4 Audit trail

Unifolio relies on Supabase's built-in audit infrastructure rather than maintaining a custom `audit_log` table. Specifically:

- **Supabase Auth** logs every sign-in, sign-out, password change, and account-deletion event with timestamp and IP (visible at `https://supabase.com/dashboard/project/<id>/auth/users` and via the Postgres `auth.audit_log_entries` table managed by gotrue).
- **Supabase Postgres logs** capture every API call hitting `delete_unifolio_user_data` and `delete_unifolio_account` RPCs (visible at `https://supabase.com/dashboard/project/<id>/logs/postgres-logs`).
- **Vercel function logs** capture every HTTP request, including the deletion request that triggers the RPC call.

Retention is governed by Supabase's tier policy (currently 7 days on Free; longer on Pro). When Unifolio upgrades to Supabase Pro, log retention will extend automatically. A dedicated application-level audit table writing structured event rows is on the 2026 roadmap and will be added before any contractor onboarding.

4. Backup retention

Supabase performs **automated daily backups** of the entire Postgres database according to its tier policy (Unifolio is currently on Supabase Free, which provides daily backups). Backup storage is encrypted at rest by AWS KMS and access is restricted to Supabase staff under their SOC 2 II controls.

After a deletion request:

- The deleted record is gone from the **live database** within 24 hours.
- It may persist in **encrypted backup snapshots** for up to the Supabase tier-defined retention window (currently 7 days on Free tier) before backup rotation purges it.
- Backup data is **only ever accessed for disaster recovery** and is never used for normal queries.

Point-in-time recovery (PITR) and longer backup retention will be enabled when Unifolio upgrades to Supabase Pro (trigger: first ≥ 5 paying users or any incident requiring sub-day recovery).

If a user explicitly requests their data be removed from backups before the rotation window completes (a rare GDPR request), we will document the request and confirm completion within an additional 30 days.

5. Plaid-specific retention

Per the Plaid Production Customer Agreement:

- Plaid `access_token` revocation via `/item/remove` is performed immediately when the user explicitly disconnects an Item from Settings.
- On full account deletion, the database row containing the access token is hard-deleted within 24 hours. Calling `/item/remove` against Plaid's API as part of the cascade is a roadmap item (Q3 2026) — currently the user-facing flow prompts the user to disconnect Plaid Items prior to triggering account deletion.
- Plaid `item_id` and institution metadata are deleted from our database within 24 hours of any deletion request.
- Cached Plaid account/transaction data is deleted alongside the rest of the user's portfolio data.
- Unifolio retains no Plaid Link credentials at any point — Plaid handles all underlying broker authentication.

6. Export rights

Before deletion, users can export their full data via:

Settings → Privacy & Data → Export your data

Exports include:

- Full JSON dump of all portfolio data
- Holdings CSV
- Transactions CSV
- Realized gains CSV

These are generated client-side from the user's own data and downloaded directly to their device — no copy is created on our servers.

7. Verification & monitoring

- After every account-deletion request, the CEO spot-checks Supabase's `auth.audit_log_entries` and Postgres RPC logs (within their tier-defined retention window) to confirm the deletion event succeeded and no orphaned records remain.
- A quarterly query is run to detect any potential orphans:

```
```sql
-- Holdings without a matching auth.users row
SELECT COUNT(*) FROM holdings h
LEFT JOIN auth.users u ON u.id = h.user_id
WHERE u.id IS NULL;
```
```

- Any orphaned rows discovered are deleted manually within 7 days and the deletion query is re-run to confirm.
-

8. Records of processing

Per GDPR Article 30, Unifolio maintains records of processing activities. These are documented in:

- **PRIVACY_POLICY.md** — public-facing summary
- **INFOSEC_POLICY.md** — internal vendor + data-flow inventory
- This document — retention specifics

The combined set is reviewed annually by the CEO.

9. Policy changes

This policy is reviewed and updated:

- **Annually** at minimum.
- **On any material change** to deletion procedures, retention windows, or applicable regulation.

The change history is the Git commit history of this file in the public Unifolio repository.

Acknowledgement

— Ahmed Al-Samak, CEO, Unifolio Inc.

2026-05-13